



MASTER OF SCIENCE
IN ENGINEERING

TSM_SecIndOpT

Threat models in OT systems (II)

Version: 2.1, by T. Mesot

whoami



Titouan Mesot - IT/OT Security Specialist

EXPERTISE: OT/ICS Cybersecurity, Security Testing, Embedded Systems

BACKGROUND: BSc. in Telecommunication (Networks and Security)

KEY INDUSTRIES: Utilities, Industrial systems, Mobility, Medical

CertX is the foundation of its ecosystem, and the First Swiss Certification Body for Functional Safety and Cyber Security accredited by Swiss Accreditation Service (SAS) with international validity

CertX AG

Passage du Cardinal 5
1700 Fribourg
Switzerland



CertX Solutions is the consultancy branch from CertX ecosystem, sharing top-level expertise and background experiences with industrial customers for helping them complying with best security, safety and AI practices aiming to reach compliance with regulatory framework and State-of-the Art

CertX Solutions AG

Passage du Cardinal 5
1700 Fribourg
Switzerland



Threat models in OT systems – Agenda

MODULE A

Introduction to Threat Analysis & Risk Assessment [TARA]

Threat Analysis & Risk Assessment introduction & walkthrough

- Risk assessment scope: System vs Product perspective
- Key concepts: Security-by-design, holistic approach, defense-in-depth...
- TARA primitives & relationships
- TARA walkthrough part I
 - System definition & security attributes
 - Damage scenario & impact rating
 - Threat scenario identification

Medical environment use case – Domestic medical device – Part 1

- System under Considerations [SuC] definitions & damages scenario
- Threat scenario identification

MODULE B

Applied Threat Analysis & Risk Assessment [TARA]

Threat Analysis & Risk Assessment walkthrough follow-up

- TARA walkthrough part II
 - Attack path analysis & feasibility rating
 - Risk value computation & treatment decisions

Medical environment use case – Domestic medical device – Part 2

- Attack trees & feasibility rating
- Risk values & alternative treatment

Wrap-up and challenges

- Upcoming regulations & challenges

Medical environment use case – Professional medical device

[optional homework]

Use case #1: Domestic Medical Device

The Ankle Monitor Predictor of Stroke (AMPS)

System definition

AMPS is a fictional home use medical device worn at night (or when resting) by patients considered at risk for a stroke. The AMPS system gathers medical readings that can be later analyzed by a medical professional. While the system can help predict a patient's risk of experiencing a stroke, it does not alert – and is not intended to alert – if a stroke is imminent or occurring

- *Period of expected use: One to three months*
- *Medical capability: Diagnostic only*
- *Device invasiveness: Low (easily removable, like a wristwatch)*

Scenario

Alice has been informed by her doctor, based on her family history and several other risk factors, that she is at increased risk of experiencing a stroke. To gain further insight and determine a treatment plan, her doctor has instructed her to take the AMPS system home and wear it when she sleeps to take readings. She is also directed to install a **companion app on her phone** that will connect to the **AMPS system** (via Bluetooth Low Energy) and upload the readings every day to the **AMPS cloud service**, where they will be analyzed by an automated algorithm. Alice's doctor will check the results after the first week to identify any immediate causes of concern, and they will schedule a follow-up consult in two months

Use case #1: Domestic Medical Device

System definition

AMPS Device

AMPS is a health monitoring system worn on a patient's ankle when they are resting. It has the following specifications and capabilities:

- On/off switch
- Physical Bluetooth pairing button
- Proprietary stroke-predicting sensor.
- Heart rate monitor
- Body temperature sensor
- Bluetooth Low Energy (BLE) connectivity
- Onboard computer and flash storage that can store up to two weeks of patient data for later transmission

AMPS Cloud Service

The AMPSCS is a collection of virtual machines hosted in a cloud infrastructure. It consists of the following functionality:

- An application gateway server to inspect and limit traffic going into the AMPSCS systems
- A set of backend services that perform analysis of the patient data
- A collection of patient-facing services that communicate with the patient app, provide a web portal for patients to register their AMPS device, and authorize clinicians to view their data
- A collection of health delivery organization (HDO)-facing services that provide a web portal for clinicians to create an account and access a patient's data
 - Clinicians' access to the portal using a web browser.
 - Authentication is provided via username and password.
 - Clinician service identifiers that clinicians can provide to patients so the patients can authorize them through the app.
 - The clinicians can view a summary of the patient's raw data and the analysis performed by the AMPSCS backend algorithms.
 - The ability for clinicians to download a patient's data via an encrypted zip file.

[13]

Use case #1: Domestic Medical Device

System definition

AMPS Patient App

There are two different versions of the patient app, one for Apple iOS, and another for Android devices. Both apps contain the following functionality:

- It can pair with the AMPS device via Bluetooth.
- It contains an interface for a patient to create an account with the AMPS cloud services, register an AMPS device, and authorize clinicians to view their data.
- If the patient gives permission to the app, it will automatically connect to the AMPS device once a day and upload readings to the AMPSCS. If the patient does not give it permission, the app will store the data retrieved from the AMPS device until a manual upload is initiated. The amount of data transferred per upload is typically less than 1 megabyte a day.
- The app will display status information to the patient, including the last time the app synced with the AMPSCS, a log of the days the app was able to pull data from the AMPS device, and a log listing if the AMPS device was successfully collecting data.
- There is a device management screen that primarily focuses on diagnosing Bluetooth connection problems, and common issues that may prevent the AMPS device from collecting data. In addition:
 - The app can wipe patient data from the AMPS device.
 - The app can check for and update the firmware of the AMPS device with new versions.
 - The app can revert the AMPS device to factory default settings.
- If the device does not successfully sync to the cloud services once every 24 hours, an in-app notice will appear directing the patient to sync their data. After 72 hours have elapsed since a successful sync, the patient will be emailed an automatic reminder.

[13]

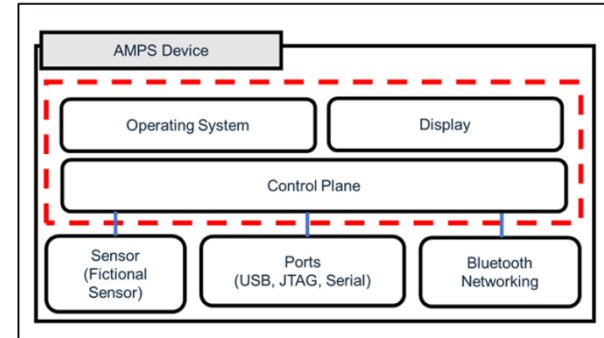
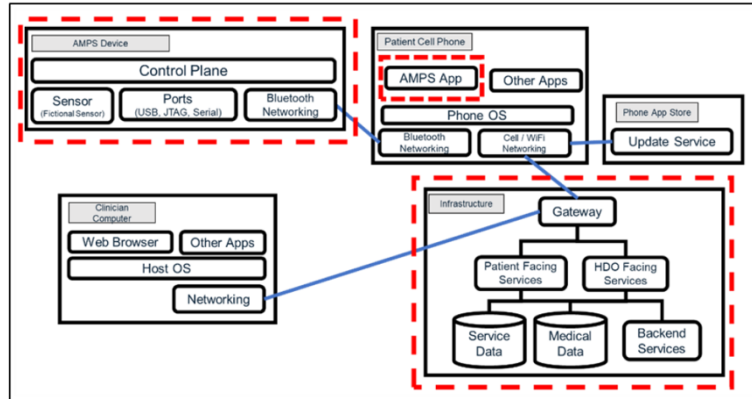
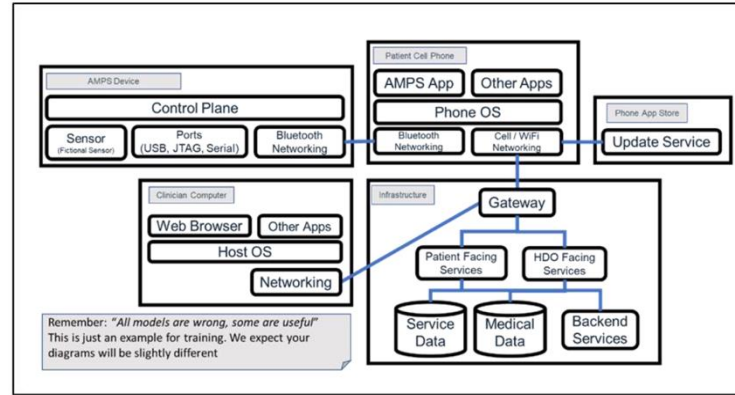
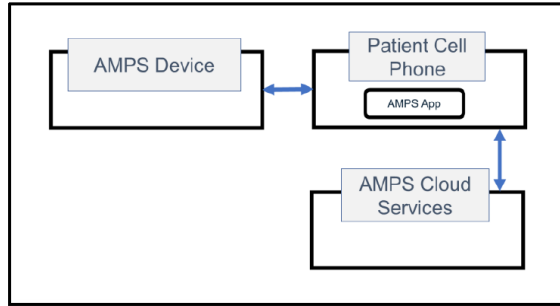
Use case #1: Domestic Medical Device

Exercise 1 – Data Flow Diagram

Draw the data flow diagram from Domestic Medical Device defined on previous slides, incl. system parts, communication flows and trust boundaries

Use case #1: Domestic Medical Device

Ex1 Data Flow Diagram



Use case #1: Domestic Medical Device

Exercise 2 – Threat scenario identification using STRIDE

Identify relevant threat scenario using STRIDE methodology, incl. at least one example per threat dimension and impact analysis

Use case #1: Domestic Medical Device

Ex2 Threat modelling

AMPS components	Threat types					
	S	T	R	I	D	E
Entity: AMPS Device	1	2	-	-	3,34 35	4
Entity: AMPS App	5,36	6	-	7	8	9,37
Entity: APP Store	10,38	11	-	12	13	14
Entity: AMPS Cloud Service	15,39 40	16,41	17,4 2 43,4 4	18,45	19,46 47,48	20,49 50
Entity: Clinician Computer	21,51 ,52	22	-	23	24,53	25
Data Flow: Bluetooth	-	-	-	26	27,54	-
Data Flow: Cellular / Wifi	-	28	-	29	30	-
Data Flow: Clinician IT network	-	31	-	32	33	-

ID	Threat type	Threat scenario identification
1	S	An attacker could pretend to be an authorized phone app to obtain readings from the device
2	T	Control plane could be attacked and given incorrect readings
3	D	Invalid input could cause device to crash
34	D	Software could be corrupted
35	D	Battery could be drained more rapidly than normal
4	E	Device could be hacked, and software could be installed to perform other actions (such as make it part of a botnet, enable lateral movement, etc.)

Use case #1: Domestic Medical Device

Threat modelling

- Repudiation
 - Device denies configuration or firmware changes
 - Device denies having performed a measurement
- Information disclosure
 - Health data is sent over an unencrypted Bluetooth connection
 - Firmware extraction over JTAG

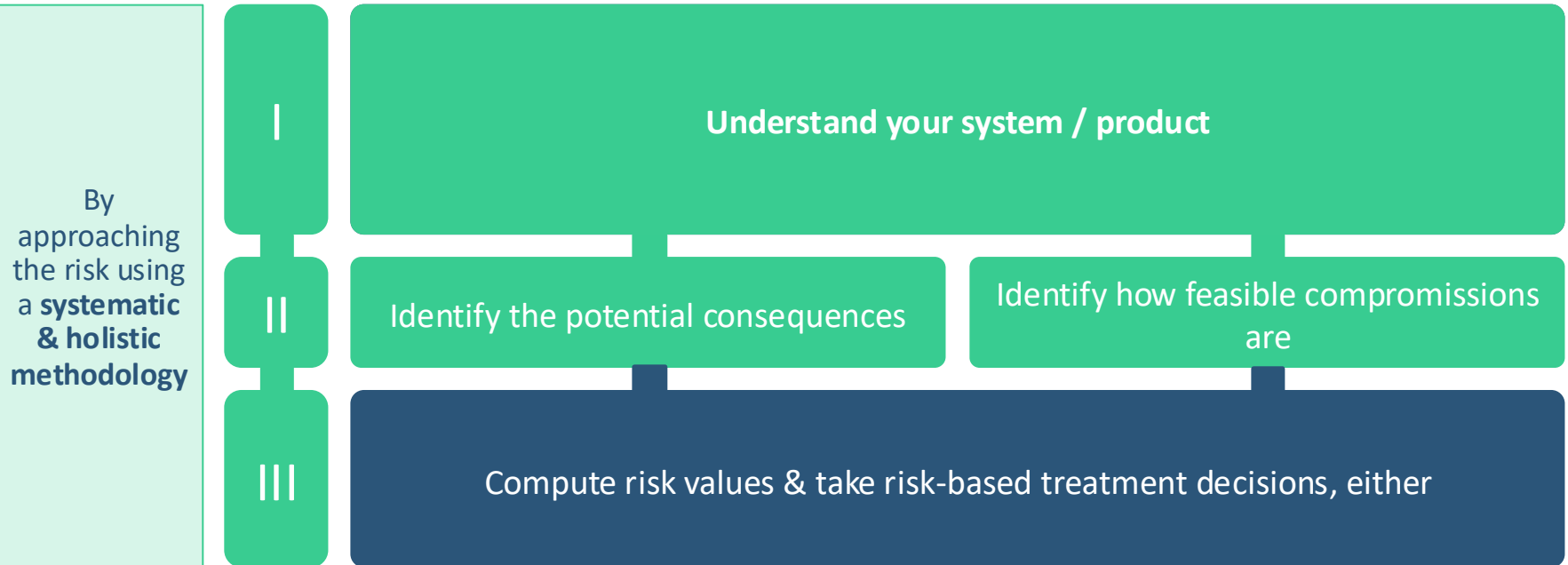
Use case #1: Domestic Medical Device

Ex2 Threat modelling

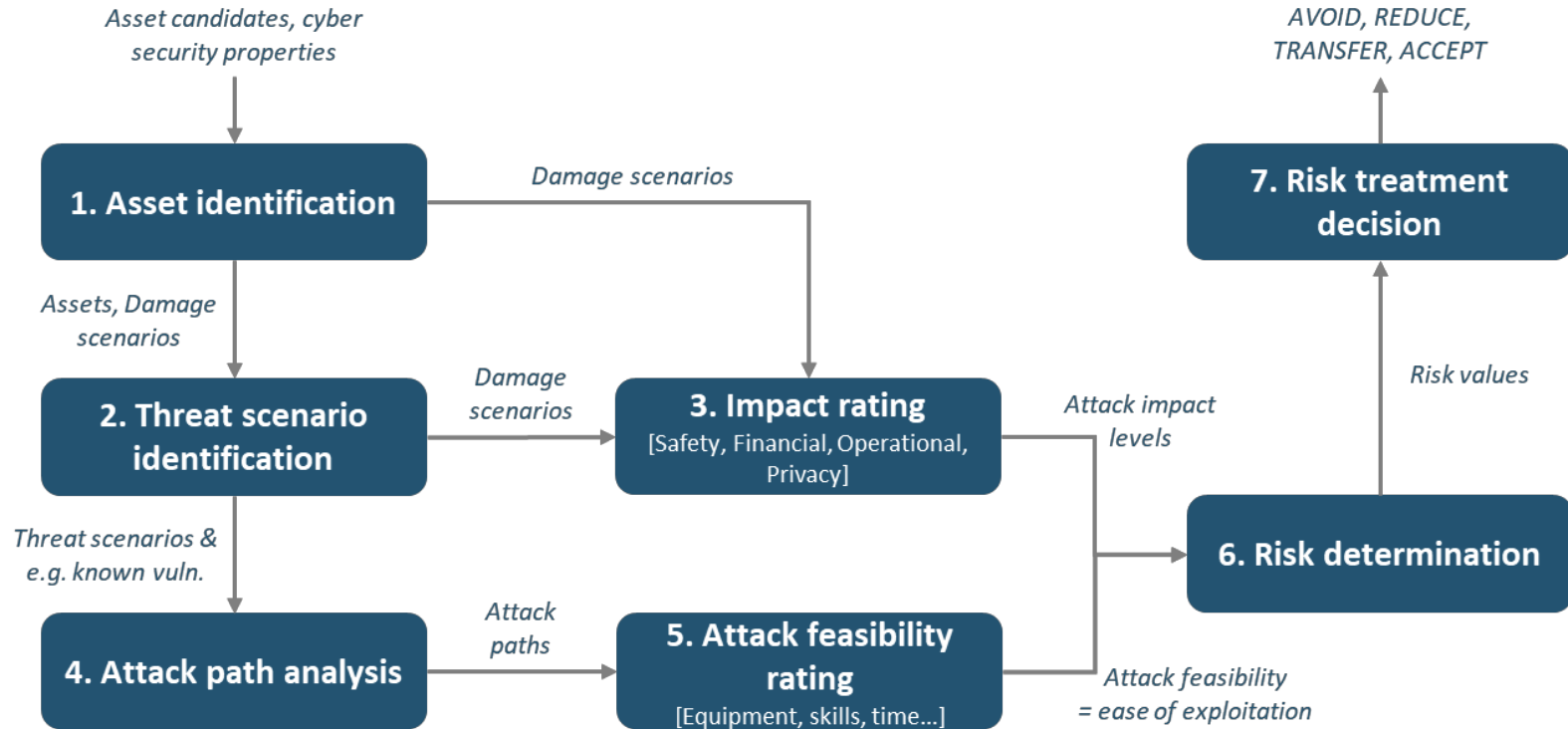
ID	Threat type	Threat scenario identification	Impact Rating [<u>S</u> afety, <u>F</u> inancial, <u>O</u> perational, <u>P</u> rivacy]	Worst impact
1	S	An attacker could pretend to be an authorized phone app to obtain readings from the device	Erroneous diagnostic [S-O], PII leakage [F-P]	P: Severe
2	T	Control plane could be attacked and given incorrect readings	Erroneous diagnostic [S-O]	S-O: Major
3	D	Invalid input could cause device to crash	System / function degradation [F-O]	O: Moderate
34	D	Software could be corrupted	Erroneous diagnostic [S-O], System / function unavailability or degradation [F-O], PII leakage [F-P]	P: Severe S-O: Major
35	D	Battery could be drained more rapidly than normal	System / function degradation [F-O]	O: Moderate
4	E	Device could be hacked, and software could be installed to perform other actions (such as make it part of a botnet, enable lateral movement, etc.)	Erroneous diagnostic [S-O], System / function unavailability or degradation [F-O], PII leakage [F-P]	P: Severe S-O: Major

TARA Process – Walk through

How to identify the relevant threats, assess them using reasonable metrics and initiate the integration of such key security principles ?



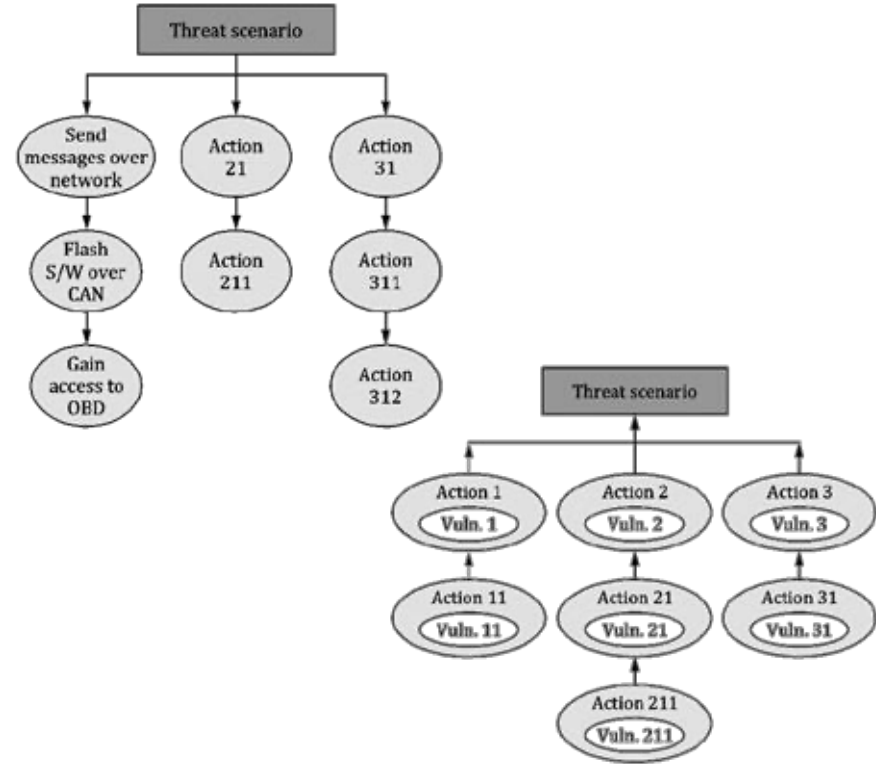
TARA Primitives – Relationships



TARA Process – 2nd step (a) – Attack trees

Threat scenarios shall be analyzed to describe possible attack paths. An attack path analysis approach can be based on:

- Top-down approaches such as attack trees, attack graphs, taxonomy mnemonic-based approaches (e.g., STRIDE): is useful in the concept and development phases when implementation of the current item or component is not available, or when effort is directed toward building attack hypotheses or attack path models.
- Bottom-up approaches (e.g., the output of vulnerability analysis): is most commonly used when an implementation of the item or component is available, or when hypotheses or attack model are to be confirmed.
- Combination of top-down and bottom-up



TARA Process – 2nd step (a) – Attack trees

Attack Path / Tree	Attack Path Step ID	#1	#2	#3	#4	#5	#6	#7	TOTAL	Aggregated and total feasibility
Physical sabotage of IPC / Edge device	AP01	APS01	APS09	-	-	-	-	-	7	High
Windows 11 Malware installation on IPC remotely	AP02	APS02	APS03	APS06	APS10	APS11	-	-	18	Medium
Windows 11 Malware installation on IPC locally	AP03	APS01	APS06	APS10	APS11	-	-	-	8	High
Windows 11 Malware installation on Edge device remotely	AP04	APS02	APS07	APS10	APS11	-	-	-	8	High
Windows 11 Malware installation on Edge device locally	AP05	APS01	APS07	APS10	APS11	-	-	-	8	High
Denial of service Windows Operating system on IPC remotely	AP06	APS02	APS03	APS06	APS13	-	-	-	18	Medium

APS02	Get network access to plant network via IT attack - Assumption / Precondition: no strong segmentation between IT and plant network
APS03	Get network access to cabinet internal network from plant network - Assumption / Precondition: having access to plant network
APS06	Get network access to IPC Operating System - Assumption / Precondition: having access to IPC Network segment (locally or remotely)
APS10	Develop malware targeting Windows 11
APS11	Install malware on Windows 11 - Assumption / Precondition: can interact with Windows 11 host at user privilege level

TARA Process – 2nd step (a) – Attack feasibility

For each attack path the attack feasibility rating shall be determined as one of the following: high, medium, low, or very low. Several methods are existing, depending on company strategy, available information and maturity of system / product development and implementation

- Attack vector-based approach: based on the evaluation of the predominant attack vector of the attack path -> basic approach but could be useful for early-stage assessment
- CVSSx based approach: should be determined based on the exploit metrics group of the base metrics, including attack vector, attack complexity, privileges required, and user interaction
- Attack potential-based approach (see ISO/IEC 18045 for factors): should be determined based on core factors including elapsed time, specialist expertise, knowledge of the item or component, window of opportunity, and equipment

TARA Process – 2nd step (a) – Attack feasibility

Attack vector-based approach (see ISO/SAE 21434 annex G for additional information about criteria)

Attack feasibility rating	Criteria
High	Network: Potential attack path is bound to network stack without any limitation. EXAMPLE 1 Cellular network connection making the ECU directly connected and accessible on the internet.
Medium	Adjacent: Potential attack path is bound to network stack; however, the connection is limited physically or logically. EXAMPLE 2 Bluetooth interface, virtual private network connection.
Low	Local: Potential attack path is not bound to network stack and threat agents require direct access to the item for realizing the attack path. EXAMPLE 3 Universal serial bus mass storage device, memory card.
Very low	Physical: Threat agents require physical access to realize the attack path.

[12]

TARA Process – 2nd step (a) – Attack feasibility

Attack vector-based approach applied to automotive use case

Threat Scenario No.	Threat Scenario	Attack Path No.	Attack Path
T.x	Spoofing of a signal leads to loss of integrity of the CAN message of "Lamp Request" signal of Power Switch Actuator ECU	AP.x	An attacker compromise Navigation ECU from Cellular interface
			Compromised Navigation ECU transmits malicious control signals
			Gateway ECU forward the malicious signals to Power Switch Actuator
			The malicious signals spoof the lamp switch on request
		AP.y	An attacker compromise Navigation ECU from Bluetooth interface
			Compromised Navigation ECU transmits malicious control signals
			Gateway ECU forward the malicious signals to Power Switch Actuator
			The malicious signals spoof the lamp switch on request
		AP.z	An attacker sends malicious control signals from OBD2 connector
			Gateway ECU forward the malicious signals to Power Switch Actuator
			The malicious signals spoof the lamp switch on request
		:	:

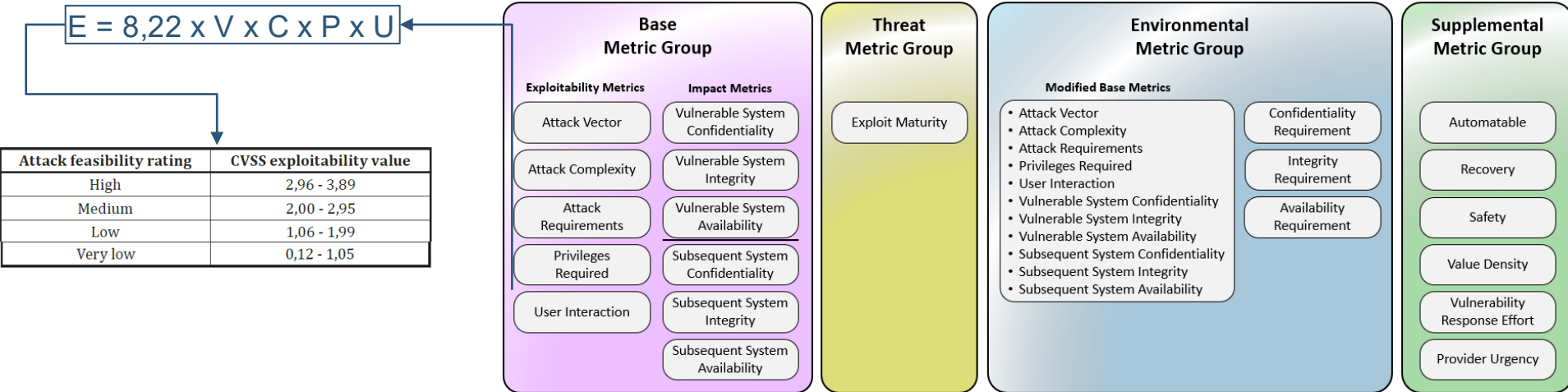
Attack path	Attack feasibility rating
i. Attacker compromises navigation ECU from cellular interface. ii. Compromised navigation ECU transmits malicious control signals. iii. Gateway ECU forwards malicious signals to power switch actuator. iv. Malicious signals spoof the lamp request (ON).	High
i. Attacker compromises navigation ECU from Bluetooth interface. ii. Compromised navigation ECU transmits malicious control signals. iii. Gateway ECU forwards malicious signals to power switch actuator. iv. Malicious signals spoof the lamp request (ON).	Medium
i. Attacker sends malicious control signals from OBD2 connector. ii. Gateway ECU forwards the malicious signals to power switch actuator. iii. Malicious signals spoof the lamp request (ON).	Low

[12]

TARA Process – 2nd step (a) – Attack feasibility

CVSS4 based approach (may provide both impact & feasibility information since CVSS4)

- Require a higher level of cyber security maturity
- Allow a smooth integration of later stages vulnerability considerations



TARA Process – 2nd step (a) – Attack feasibility

Attack potential-based approach (see ISO/IEC 18045 for factors):

Elapsed time		Specialist expertise		Knowledge of the item or component		Window of opportunity		Equipment	
Enumerate	Value	Enumerate	Value	Enumerate	Value	Enumerate	Value	Enumerate	Value
≤1 day	0	Layman	0	Public	0	Unlimited	0	Standard	0
≤1 week	1	Proficient	3	Restricted	3	Easy	1	Specialized	4
≤1 month	4	Expert	6	Confidential	7	Moderate	4	Bespoke	7
≤6 months	17	Multiple experts	8	Strictly confidential	11	Difficult/none	10	Multiple bespoke	9
>6 months	19								

Attack feasibility rating	Values
High	0 - 9
	10 - 13
Medium	14 - 19
Low	20 - 24
Very low	≥ 25

[12]

TARA Process – 2nd step (a) – Attack feasibility

feasibility

Criteria				Criteria description		Parameter		
Elapsed time				The elapsed time scale includes the time to identify a vulnerability and develop and (successfully) apply an exploit. Therefore, this rating is based on the state of expert knowledge at the time of rating		< 1 day	0	"Layman" is unknowledgeable compared to experts or proficient persons, with no particular expertise; Examples may include persons who can only follow simple instructions that come with the available tools to mount simple attacks, but not capable of making progresses himself/herself if the instructions or the tools do not work as expected.
						<= 1 week	1	"Proficient" persons have general knowledge about the security field and are involved in the business, for example, workshop professionals. Proficient persons know about simple and popular attacks. They are capable of mounting attacks, for example, odometer tuning and installing counterfeit parts, by using available tools and if required, are capable of improvising to achieve the desired results.
						<= 1 month	4	"Proficient" persons have general knowledge about the security field and are involved in the business, for example, workshop professionals. Proficient persons know about simple and popular attacks. They are capable of mounting attacks, for example, odometer tuning and installing counterfeit parts, by using available tools and if required, are capable of improvising to achieve the desired results.
						<= 6 months	17	"Experts" are familiar with the underlying algorithms, protocols, hardware, structures, security behavior, principles and concepts of security employed, techniques and tools for the definition of new attacks, cryptography, classical attacks for the product type, attack methods, etc. implemented in the product or system type.
						> 6 months	19	The level "Multiple Experts" is introduced to allow for a situation, where different fields of expertise are required at an Expert level for distinct steps of an attack.
Knowledge about TOE				The parameter "Knowledge about TOE" refers to the availability of information about the TOE and the community size that possesses knowledge about the TOE from an attacker perspective. This parameter points to the sources from where attackers can gain knowledge about the TOE and indicates how easy or difficult it can be for an attacker to acquire knowledge about the TOE		Layman	0	Unknowledgeable compared to experts or proficient persons, with no particular expertise. EXAMPLE: Ordinary person using step-by-step descriptions of an attack that is publicly available.
						Proficient	3	Knowledgeable in that they are familiar with the security behavior of the product or system type. EXAMPLE: Experienced owner, ordinary technician knowing simple and popular attacks like odometer tuning, installation of counterfeit parts.
						Expert	6	Familiar with the underlying algorithms, protocols, hardware, structures, security behavior, principles and concepts of security employed, techniques and tools for the definition of new attacks, cryptography, classical attacks for the product type, attack methods, etc. implemented in the product or system type. EXAMPLE: Experienced technician or engineer
						Multiple Experts	8	Is introduced to allow for a situation, where different fields of expertise are required at an Expert level for distinct steps of an attack.
						Window of Opportunity		
Easy	1	High availability and limited access time. Remote access without physical presence, as well as limited physical access to the item or component. EXAMPLE: Attacker enters an unlocked car and got access to exposed physical interface, e.g., physical access via on-board diagnostic port, or a remote attack that requires the vehicle standing still.						
Moderate	4	Low availability of the item or component. Limited physical and/or logical access. Physical access to the vehicle interior or exterior without using any special tools.						
Difficult / None	10	Very low availability of the item or component. Impractical level of access to the item or component to perform the attack.						
Equipment				The parameter "Equipment" refers to the equipment required to identify or exploit vulnerability and/or mount an attack				
						Specialized	4	Equipment is not readily available to the attacker but can be acquired without undue effort. This can include purchase of moderate amounts of equipment (e.g., power analysis tools, use of hundreds of PCs linked across the internet would fall into this category), or development of more extensive attack scripts or programs. If clearly different test benches consisting of specialized equipment are required for distinct steps of an attack this would be used as bespoke.
						Bespoke	7	Equipment is not readily available to the public (e.g., black market) as it may need to be specially produced (e.g., very sophisticated software), or because the equipment is so specialized that its distribution is controlled, possibly even restricted. Alternatively, the equipment may be very expensive. EXAMPLE: Manufacturer-restricted tools, electron microscope.
						Multiple bespoke	9	Is introduced to allow for a situation, where different types of bespoke equipment are required for distinct steps of an attack.

generic knowledge of the
ods that are required to

[12]

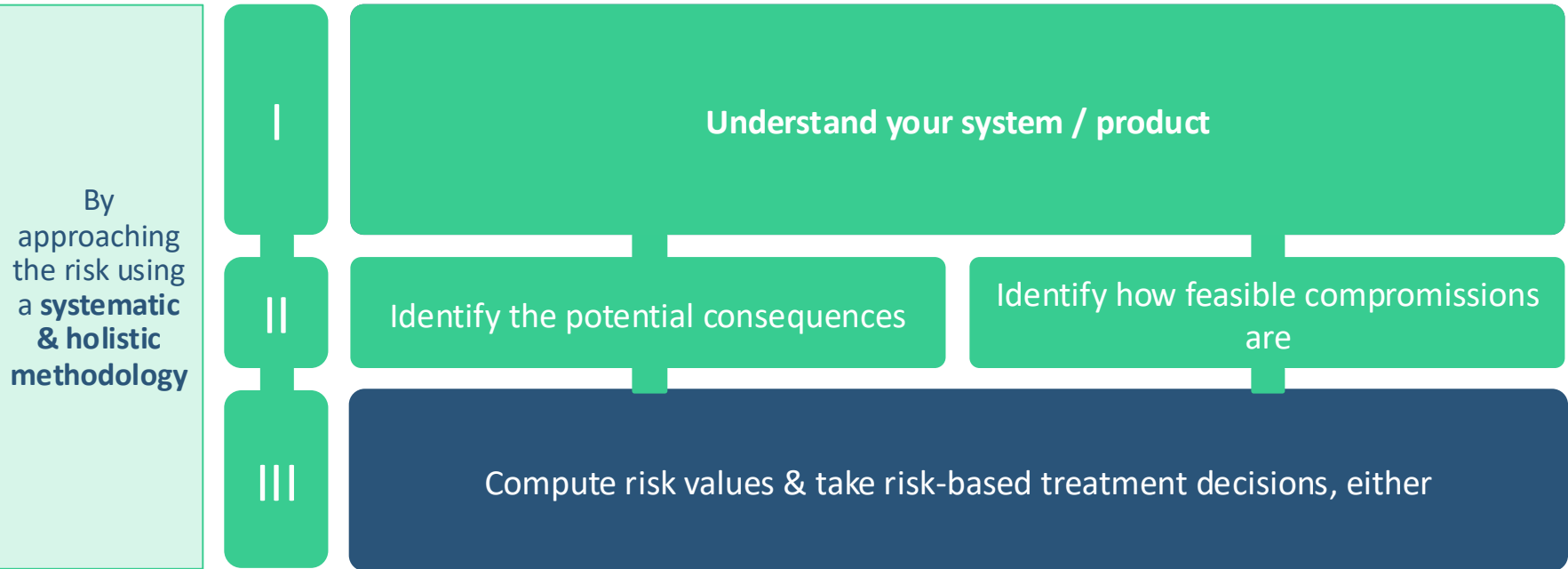
[12]

TARA Process – 2nd step (a) – Attack feasibility

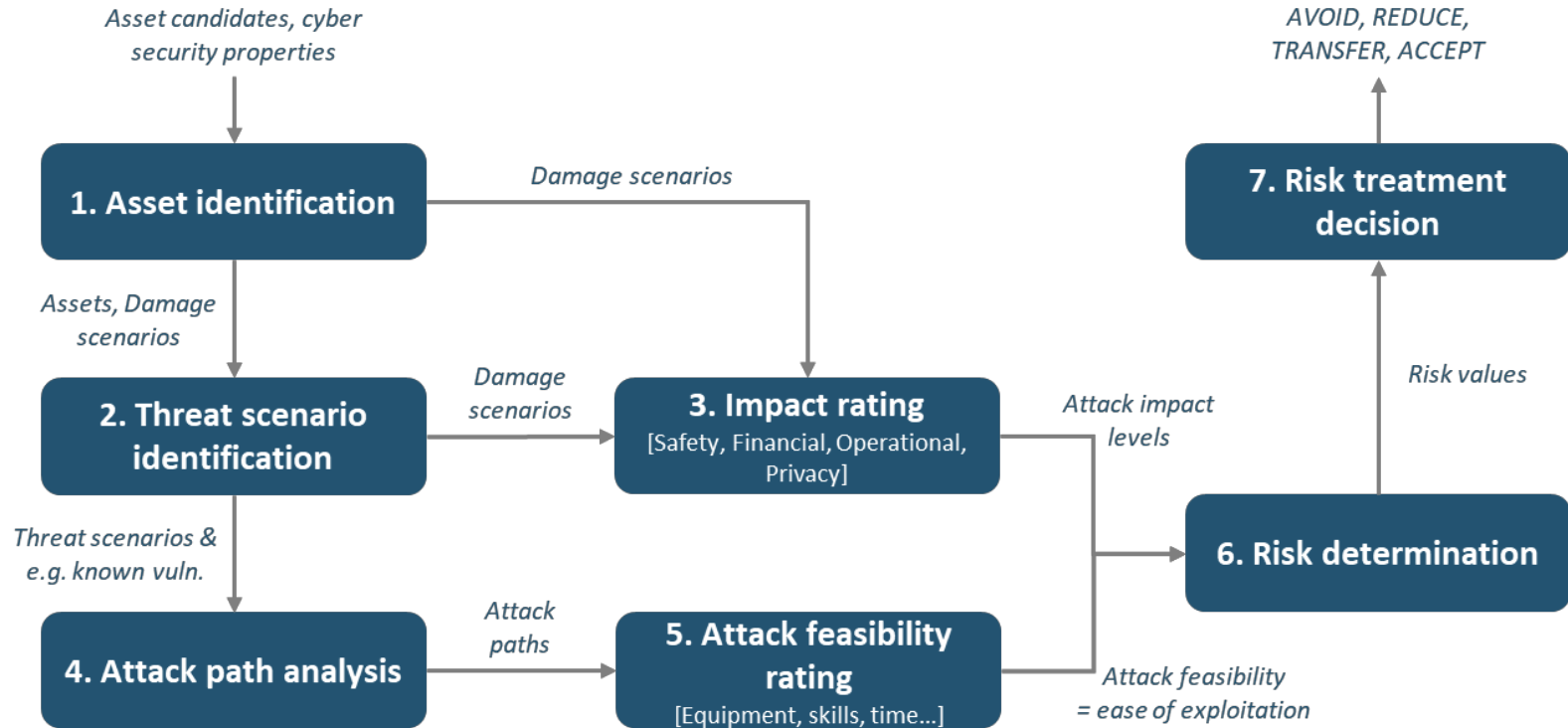
4. ATTACK PATH ANALYSIS		5. INITIAL ATTACK FEASIBILITY RATING (without CS measures)						
Attack Path Step ID	Attack Path Step Description	Elapsed time	Expertise	Knowledge	Window of opportunity	Equipment Required	TOTAL	Aggregated and total feasibility
APS01	Get physical access to device via panel or open service port	< 1 day	Layman	Restricted	Moderate	Standard	7	High
APS02	Get network access to plant network via IT attack - Assumption / Precondition: no strong segmentation between IT and plant network	<= 1 week	Proficient	Restricted	Unlimited	Standard	7	High
APS03	Get network access to cabinet internal network from plant network - Assumption / Precondition: having access to plant network	<= 1 week	Expert	Confidential	Moderate	Standard	18	Medium
APS04	Get access to remote service public endpoint (cloud based) - Assumption / Precondition: no strong auth	<= 1 week	Layman	Restricted	Unlimited	Standard	4	High
APS05	Get access to internal remote access endpoint - Assumption / Precondition: internal remote access only allowed from cabinet network	< 1 day	Layman	Public	Easy	Standard	1	High
APS06	Get network access to IPC Operating System - Assumption / Precondition: having access to IPC Network segment (locally or remotely)	< 1 day	Layman	Public	Unlimited	Standard	0	High
APS22	Run Denial of Service against EtherCAT communication	< 1 day	Proficient	Public	Unlimited	Specialized	7	High
APS23	Tamper safe Ethercat (FSoE) communication	<= 1 week	Expert	Restricted	Unlimited	Specialized	14	Medium
APS24	Forge OPCUA/ADS messages	<= 1 week	Proficient	Restricted	Unlimited	Standard	7	High
APS25	Extract OPCUA/ADS messages	<= 1 week	Proficient	Restricted	Easy	Standard	8	High
APS26	Setup MITM on the network	< 1 day	Layman	Public	Easy	Standard	1	High
APS27	Forge MQTT Messages	< 1 day	Layman	Restricted	Unlimited	Standard	3	High
APS28	Tampering NTP data	< 1 day	Layman	Public	Unlimited	Standard	0	High
APS29	Compromise Windows 11 update process to use malicious update	<= 6 months	Expert	Restricted	Easy	Standard	27	Very low

Threat Analysis & Risk Assessment – HOW

How to identify the relevant threats, assess them using reasonable metrics and initiate the integration of such key security principles ?



TARA Primitives – Relationships



TARA Process – 3rd step – Risk matrices

A risk matrix is a representation of a mapping of levels of impact and attack feasibility respectively on given scales to risk values. The purpose of the determination of a risk value can be one of the following:

- to support criteria for decisions on risk treatment, incl. selection of controls;
- prioritization of risks for treatment;
- report to stakeholders; and
- monitoring of risk.

		Attack feasibility rating			
		Very Low	Low	Medium	High
Impact rating	Severe	2	3	4	5
	Major	1	2	3	4
	Moderate	1	2	2	3
	Negligible	1	1	1	1

TARA Process – 3rd step – Risk matrices

1. ASSET IDENTIFICATION					2. THREAT SCENARIO IDENTIFICATION		3. IMPACT RATING					
Asset	C	I	A	Damage Scenario Description [worst case]	Threat	Threat Scenario Description	Financial	Operational	Privacy	Safety	Worst Impact Description	Highest Impact
A03 - IPC OS		x		Damaging to the machine, to parts, or safety hazards.	Tampering	Malware changes OS files or drivers, altering timing, motion logic, or process parameters. Motion control executes commands incorrectly.	Major	Moderate	Negligible	Moderate	Default are introduce in manufactured items and safety operations are removed.	Major
A08 - Industrial communication data	x			Sensitive operational data, including machine state, recipes, or production parameters reveal trade secrets or critical operational information.	Info disclosure	An attacker eavesdrops on the industrial communication between Edge PC and external systems, capturing production data or machine configurations.	Moderate	Negligible	Major	Negligible	Loss of sensitive operational information, trade secrets exposure, and potential competitive or regulatory consequences.	Major
A08 - Industrial communication data		x		Incorrect operations, misreporting, or unsafe conditions in external systems.	Tampering	An attacker tamper on the industrial communication between Edge PC and external systems, capturing	Major	Moderate	Negligible	Moderate	Incorrect production execution, mismanagement of	Major
A08 - Industrial communication data			x	Machine axe: halted produ damage to m parts.	4. ATTACK PATH ANALYSIS		5. INITIAL FEASIBILITY ANALYSIS		6. INITIAL RISK DETERMINATION			
A09 - Remote access data		x		Unauthorized Windows 11 Malware installation on IPC remotely changes or m	Attack Path Description	Attack Path ID	inherent feasibility	Aggregated and total - initial feasibility	Initial Impact	Initial Feasibility	Risk Value [0-5]	
				Eavesdropping on industrial communication remotely		AP02	18	Medium	Major	Medium	3	
						AP21	8	High	Major	High	4	
				Tampering of industrial communication remotely		AP19	11	High	Major	High	4	
				Denial of service on industrial communication locally		AP24	7	High	Major	High	4	
				Tampering of external remote access service		AP28	18	Medium	Major	Medium	3	

TARA Process – 3rd step – Risk matrices

Finally, a risk treatment option shall be determined, considering impact categories, attack paths and the results from risk determination. Typically, risk treatment options are:

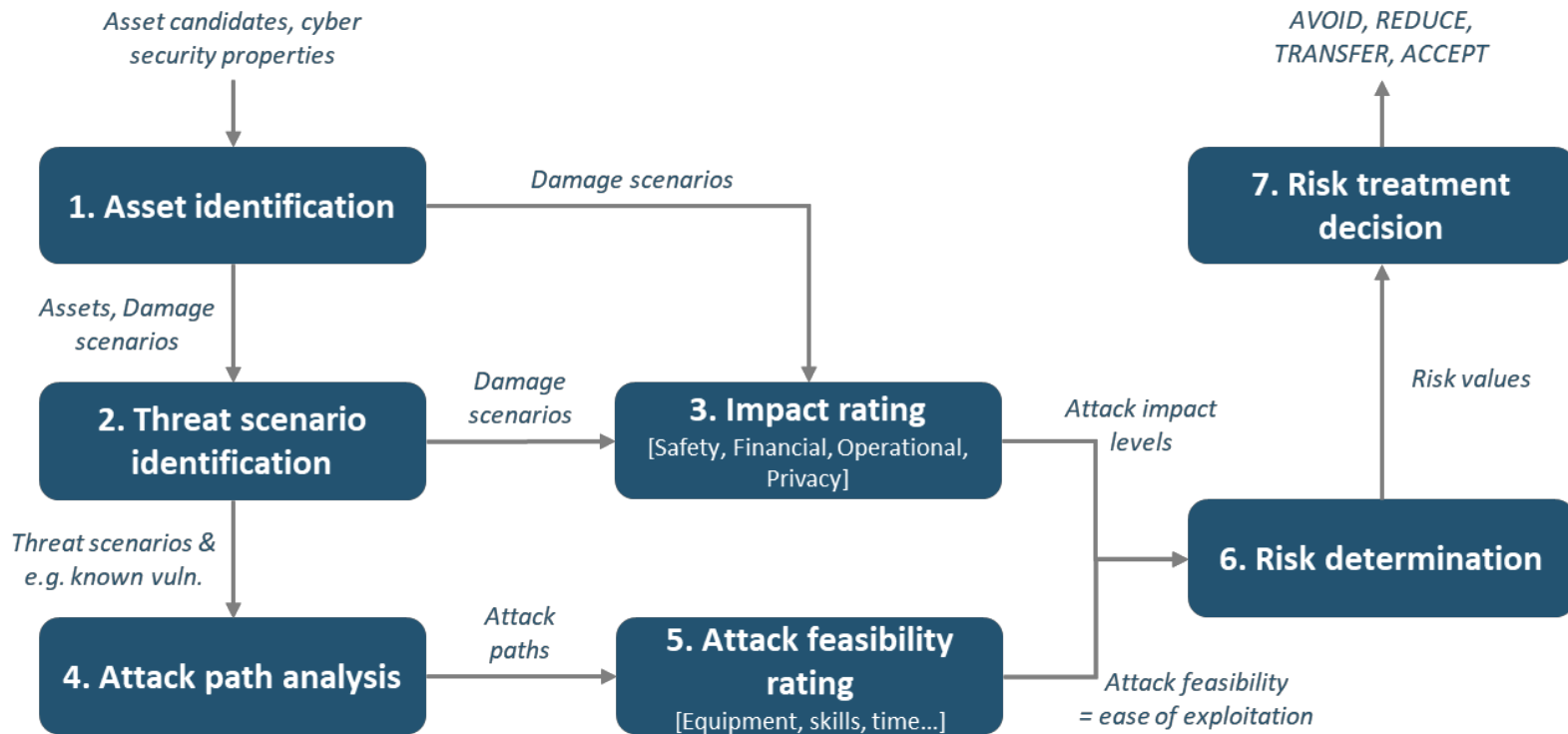
- avoiding the risk by removing the risk sources, or deciding not to start or continue with the activity that gives rise to the risk;
- reducing the risk -> cyber security measures to be identified
- sharing or transferring the risk (e.g., through contracts, buying insurance); and/or
- accepting or retaining the risk.

For risk acceptance and risk transfer, the corresponding rationales are recorded as cyber security claims and subject to validation, monitoring and vulnerability management

TARA Process – 3rd step – Risk matrices

7. INITIAL RISK TREATMENT DECISIONS					8. RESIDUAL FEASIBILITY		9. RESIDUAL RISK DETERMINATION		
Initial risk treatment options	CS Measure ID	Measure Description	CS Claims ID	Claim Description	Updated feasibility	Aggregated and total - residual feasibility	Residual Impact	Residual Feasibility	Residual Risk Value [0-5]
Reduce the risk	SM2/SM3/SM4	Strong segmentation from IT network + strong auth for IPC for remote connections + Windows integrity protection			22	Low	Major	Low	2
Reduce the risk	SM2/SM5	Strong segmentation from IT network + Use secure version of telemetry and industrial protocols			37	Very low	Major	Very low	1
Reduce the risk	SM2/SM5	Strong segmentation from IT network + Use secure version of telemetry and industrial protocols			37	Very low	Major	Very low	1
Reduce the risk	SM1	Physical protection measures			22	Low	Major	Low	2
Reduce the risk	SM3	Strong authentication			37	Very low	Major	Very low	1

TARA Primitives – Relationships



TARA Process – And Next ?

- Security measure documentation / implementation against known catalog
- Verify effectiveness with :
 - Verification (Did we build it right ?)
 - Validation (Did we build the right thing ?)
- Review TARA after each feature update, context changes, new threat, feasibility of an attack, new vulnerability, ...
- Document each accepted or transferred risk for traceability
 - Accepted: Why ?
 - Transfer: To whom ? Why ? What must be check ?
 - Reduce: How ?
 - Avoid: How ?

TARA Process – Demo

- Demo for a full TARA for the CNC

The table is a detailed TARA (Task Analysis) for a CNC machine. It is organized into columns for various stages of the task, including 'Task', 'Sub-task', 'Action', 'Condition', 'Error', and 'Mitigation'. The table contains numerous rows of data, with some cells highlighted in orange, green, and blue to indicate different levels of risk or status. The table is titled 'TARA - CNC Machine' at the top left.

Use case #1: Domestic Medical Device

Exercise 3 – Attack trees

Based on assumption you may define, either list attack path steps, or draw down attack trees related to following threat scenarios

1. “An attacker could pretend to be an authorized phone app to obtain readings from the device”
2. “Invalid input could cause device to crash”

Assuming impact rating as SEVERE for (1) for privacy issues, and MODERATE for (2) for operational issues, compute risk values and propose risk treatment decisions

TARA Process – Wrap up

How to identify the relevant threats, assess them using reasonable metrics and initiate the integration of such key security principles ?

By
approaching
the risk using
a **systematic
& holistic
methodology**

I

Understand your system / product, including

- What function does it provide ?
- What architecture part do we have ? What security properties matters (CIA) ?
- What lifecycle phases do exist ?
- What are my internal / external stakeholders ? Which (trust) boundary do we have ?
- What are my assumptions around its operational environment ?

II

Identify the potential consequences

- Safety | Financial | Operation. | Legal
- What regulatory binding rules ?

Identify how feasible compromissions are

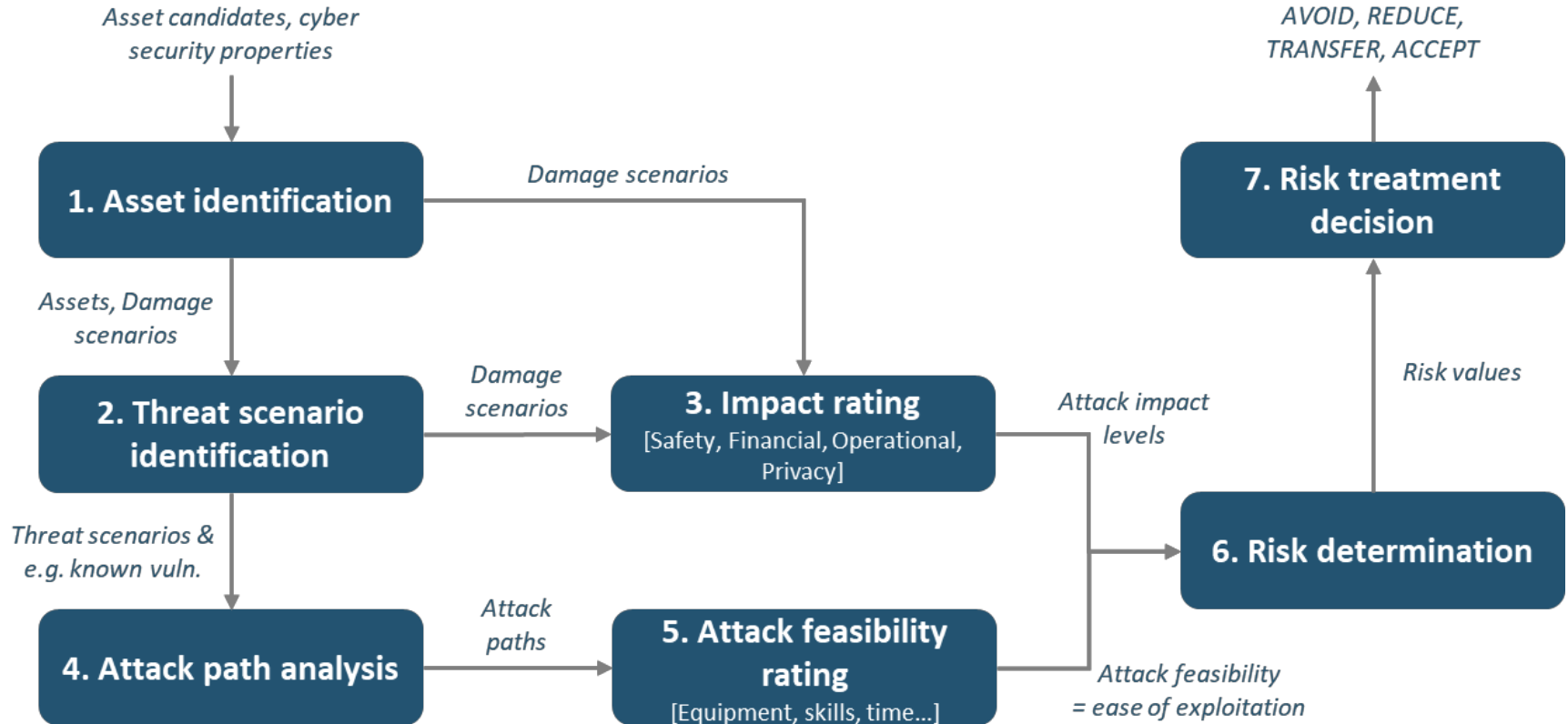
- What attack vectors & chain ?
- How «feasible» or complex ?

III

Compute risk values & take risk-based treatment decisions, either

- Accept the risk – Document rationale for acceptance
- Reduce the risk – identify security measures & controls to be implemented and controlled
- Avoid the risk – remove risk sources | *not that usual.*
- Transfer the risk – identify risk sharing with other parties (e.g. integrators, insurances...)

TARA Process details



TARA Process reviews (I)

Checklist for Evaluating a “Good Job” in Documentation

- **Completeness**: Is all information within the STRIDE analysis (or other analyses) complete? Within each aspect of the threat model, are all sub-elements complete? For example, Attack Trees can be more dependent on ability and expertise of the threat modeler to come up with sufficiently comprehensive set of attacks that inexperienced developers might not think of. Were the strongest possible mitigations identified, and for each component? If there are gaps, is it well understood why those gaps exist?
- **Clarity**: Is each threat, mitigation, etc., clearly explained? Does it make sense for the intended audience(s)? Ideally, clarity would emerge naturally with the iterative nature of threat modeling across a variety of participants within the organization, but there would still be external consumers—and some issues of clarity could be explained in meetings or email without being updated within the documentation itself.
- **Specificity**: Is each element appropriately specific and at the right level of detail for the intended audience(s)? For example, giving the name of a protocol might be sufficient in some cases, whereas the protocol, version number, and configuration mode might be necessary for others.

TARA Process reviews (II)

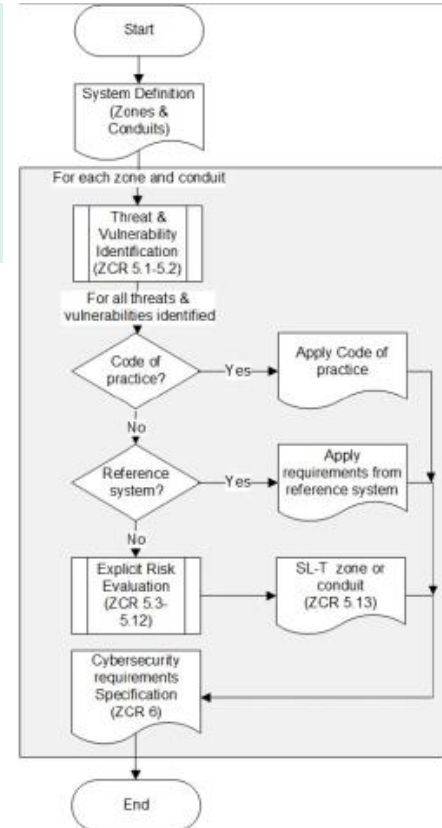
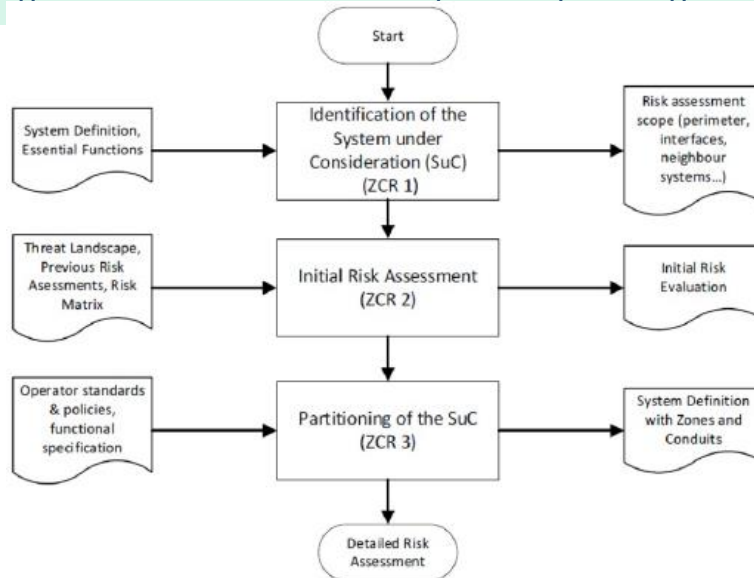
Checklist for Evaluating a “Good Job” in Documentation - continued

- **Traceability**: Are interrelationships between different components of the threat model easily traceable? If identifiers are used, are they consistent and correct? Are there any identifiers that are cited but not defined? Are there multiple entries or descriptions for the same concept within the same context (i.e., duplicates)?
- **Consistency**: Is there consistency between the intended design and the implementation of the manufactured device? Documentation can change frequently due to the iterative approach of threat modeling, so inconsistencies can arise.
- **Roles and responsibilities**: When applicable to the threat model or risk analysis, are the roles and responsibilities of the medical device operators, patients, and other parties clearly identified, particularly when discussing risk?
- **Assumptions**: Are all assumptions clearly identified? Are these assumptions “reasonable”?
- **Rationales**: Are rationales for decisions included in sufficient detail, especially for cases in which risks are accepted or transferred; is there some ability to revisit why one mitigation is selected over another; etc.?

System security risk assessment within OT



Risk assessment on system (=infrastructure) level is usually not following the same strategy, due to the wider landscape of sub systems and threats to be addressed. ISA/IEC 62443-3-2 is defining another framework to approach cyber security risk assessment based on Zone & Conduits segmentations – to be developed in upcoming modules



Threat Analysis & Risk Assessment – Challenges

- Lack of cyber security competences across organizations (esp. for realistic attack path evaluations)
- Lack of general cyber security strategy which lead to inconsistencies
 - Initial assumptions & rationales missing
 - Considerations about existing protection measures giving analysis bias
- Weak maturity of tooling & software support
- Need for stakeholder interactions
 - Interfaces with other risk assessments (e.g. quality, functional safety, reliability...)
 - Interfaces between IT-Sec, OT-Sec and Product-Sec
 - RASIC [Responsible, Accountable, Supportive, Informed, Consultative]
- Maintenance complexity
 - Risks are continuously evolving (e.g. attack technics, tools, known vulnerabilities...)
 - Integration of vulnerability considerations during operation phase

Threat Analysis & Risk Assessment – Resources

- **Microsoft Threat Modeling Tool:**
 - Open-source tool to generate parts of TARAs based on data flow representations, STRIDE-based
 - Open-source stencils & templates to be found online
 - Link: <https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool>
- **OWASP Threat Dragon**
 - Open-source modeling tool used to create threat model diagrams as part of a secure development lifecycle
 - Link: <https://owasp.org/www-project-threat-dragon/>
- **MITRE ATT&CK frameworks:** globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is used as a foundation for the development of specific threat models and methodologies in the private sector, in government, and in the cybersecurity product and service community
 - IT: <https://attack.mitre.org/matrices/enterprise/>
 - OT: <https://attack.mitre.org/matrices/ics/>
 - Mobile: <https://attack.mitre.org/matrices/mobile/>
 - Embedded: <https://emb3d.mitre.org/>

Conclusion

- Risk assessment is a key tool to understand cybersecurity risk and support risk-informed decision-making
- Risk assessment is mandatory in multiple regulations
 - Product with digital element with EU Cyber Resilience Act, Radio Equipment Directive and Machinery Directive
 - Critical Infrastructure with EU NIS2
 - Also medical, automotive, ...
 - In Switzerland too with ICT minimum (Mandatory in Gas, Energy producer & distributors)
- It must be integrated in the Software Development Life Cycle
 - And as early as possible
- It must be challenged and updated, it's living document